

Penetration Testing – Task 2 Report

Week 5: Vulnerability Scanning with Nessus

1. Objective

The purpose of this task was to perform a comprehensive vulnerability assessment of the target system (**Metasploitable2**) using **Nessus Essentials**, identifying known vulnerabilities, CVEs, and misconfigurations to guide exploitation in subsequent phases.

2. Target Information

- **Target Machine:** Metasploitable2
 - **Target IP:** 192.168.0.102
 - **Environment:** VirtualBox
 - **Attacker Machine:** Kali Linux
 - **Scanning Tool:** Nessus Essentials (Free Version)
-

3. Methodology

1. **Tool Setup:** Nessus Essentials installed on Kali Linux and activated.
 2. **Scan Configuration:**
 - **Scan Type:** Basic Network Scan
 - **Target IP:** 192.168.0.102
 3. **Execution:**
 - Launched scan and allowed full plugin execution.
 - Nessus used active probing to enumerate services, detect versions, and match them with known vulnerabilities from the Tenable plugin database.
 4. **Analysis:**
 - Vulnerabilities classified into **Critical**, **High**, **Medium**, and **Low** severities.
 - Findings cross-referenced with Nmap results from **Task 1**.
-

4. Summary of Findings

Severity	Count
Critical	10
High	14
Medium	18
Low	9

5. Key Vulnerabilities

Critical

1. vsftpd 2.3.4 Backdoor Command Execution

- CVE-2011-2523 – Allows remote code execution due to malicious backdoor in version 2.3.4.
- Exploitable via FTP port (21) with anonymous login enabled.

2. UnrealIRCd 3.2.8.1 Backdoor

- CVE-2010-2075 – Backdoored version allows remote shell access via IRC port (6667).

3. ProFTPD 1.3.1 Mod_Copy Command Execution

- CVE-2015-3306 – Allows arbitrary file copy and possible code execution.

4. Apache Tomcat 5.5 Default Credentials

- CVE-2009-3548 – Default admin:admin credentials allow full application control.

5. PostgreSQL 8.3 Authentication Bypass

- CVE-2009-3231 – Unauthenticated access possible under certain configurations.
-

High

1. OpenSSH 4.7p1 Multiple Vulnerabilities

- CVE-2008-5161 – Information disclosure via CBC padding oracle attack.

2. Samba 3.0.20 Remote Code Execution

- CVE-2007-2447 – “Username map script” vulnerability allows root command execution.

3. Apache HTTPD 2.2.8 Vulnerabilities

- CVE-2011-3192 – Range header DoS.
- CVE-2009-3555 – TLS renegotiation flaw.

4. MySQL 5.0.51a Multiple Vulnerabilities

- CVE-2012-2122 – Authentication bypass.

5. VNC Authentication Weakness

- CVE-2006-2369 – Weak password authentication susceptible to brute force.

Medium

1. SSLv2 Enabled on SMTP (Postfix)

- Deprecated protocol vulnerable to MITM attacks.

2. X11 Server Open Access

- Potential remote graphical session hijacking.

3. RPCBind & NFS Services Exposed

- Information disclosure & possible remote mounting.

4. Anonymous FTP Access

- Potential for unauthorized file downloads or uploads.

Low

1. Banner Grabbing Enabled – Service versions disclosed to attackers.

2. Deprecated Software Versions – No longer supported by vendors.

6. Risk Analysis

The Metasploitable2 system is intentionally vulnerable and contains multiple **Critical** remote code execution vulnerabilities. Several services (FTP, IRC, Samba, MySQL) are misconfigured and outdated, making them highly exploitable. In a real-world environment, such a system would be at **severe risk** of compromise.

7. Recommendations

1. **Remove or Disable Unused Services** – e.g., Telnet, Rlogin, VNC.
 2. **Upgrade All Outdated Software** – Replace vulnerable versions of vsftpd, Samba, Apache, MySQL, etc.
 3. **Enforce Strong Authentication** – Disable anonymous FTP and default credentials in Tomcat.
 4. **Disable Insecure Protocols** – Remove SSLv2 support from SMTP.
 5. **Restrict Network Access** – Implement firewall rules to limit service exposure.
-

8. Conclusion

The Nessus scan confirmed multiple high-risk vulnerabilities discovered in Task 1 through manual enumeration. The findings provide a strong basis for **Task 3 – Exploitation in a controlled environment**, where selected vulnerabilities will be leveraged to gain system access.
